

Spesifikasi API

dashAI — Saksi Mata Digital yang Netral & Tertandatangan

dashAI

2026-06-21

Daftar Isi

1	Ringkasan & Konvensi	2
1.1	Lingkungan & deployment	3
1.2	Konvensi umum	4
1.2.1	Catatan format tanda tangan (penting)	4
1.2.2	Identitas kunci (keyId / publicKeyId)	4
2	POST /api/seal	5
2.1	Request body	5
2.1.1	Field yang diakui dari event	6
2.2	Validasi	7
2.3	Response (200)	7
2.3.1	Struktur EvidencePayload (batas kriptografis)	8
2.4	Errors	9
2.5	Diagram alur penyegelan	10
3	POST /api/verify	10
3.1	Request body	10
3.2	Validasi	11
3.3	Logika verifikasi	11
3.4	Response (200)	11
3.4.1	Pesan reason	11
3.5	Errors	12
4	GET /api/public-key	12
4.1	Response (200)	12
4.2	Errors	12
5	POST /api/report	12
5.1	Request body	13
5.1.1	Jenis laporan (kinds)	13
5.2	Alur pemrosesan	13
5.3	Response (200)	14
5.4	Errors	14
6	Model error & kode status	14
6.1	Bentuk objek error (JSON)	15
6.2	Prinsip desain error	15

7	Pertimbangan keamanan	15
7.1	Permukaan rahasia minimal	15
7.2	Kunci DEV vs produksi	16
7.3	Batas kepercayaan (trust boundary)	16
7.4	Apa yang dibuktikan dan tidak dibuktikan tanda tangan	16
7.5	Privasi (selaras UU 27/2022 PDP)	16
7.6	Integritas verifikasi mandiri	16
7.7	Validasi input & ketahanan	17
7.8	Catatan demo (jujur soal batasan)	17
8	Contoh request/response	17
8.1	Menyegel pelanggaran “melawan arah” (kendaraan lain)	17
8.2	Menyegel “melebihi kecepatan” (diri sendiri, akurat via GPS)	18
8.3	Verifikasi envelope	19
8.4	Mengambil kunci publik	20
8.5	Membuat laporan PDF	20
9	Tabel ringkasan gaya OpenADR	20
9.1	Matriks tipe inti	21
9.2	Pemetaan pelanggaran → sitasi UU 22/2009	22

1 Ringkasan & Konvensi

Dokumen ini menetapkan kontrak HTTP untuk seluruh permukaan server dashAI. Permukaan ini sengaja dibuat **kecil**: empat endpoint, tanpa basis data, tanpa autentikasi pengguna, dan tanpa kunci API pihak ketiga. Seluruh kecerdasan deteksi (TensorFlow.js coco-ssd, IoU tracker, MediaPipe face/pose, Tesseract.js OCR pelat) berjalan **di dalam browser**; server hanya melakukan tiga hal yang tidak bisa dipercayakan ke klien:

1. **Menyegel** bukti secara kriptografis dengan Ed25519 (POST /api/seal).
2. **Memverifikasi** envelope yang sudah disegel (POST /api/verify dan halaman /verify sisi-klien).
3. **Merender** laporan PDF tertanda tangan dengan QR verifikasi (POST /api/report).

Endpoint keempat, GET /api/public-key, mempublikasikan kunci publik agar **siapa pun** dapat memverifikasi laporan tanpa harus mempercayai antarmuka dashAI.

Catatan integritas. dashAI bersifat **tamper-evident**, bukan **tamper-proof**. Tanda tangan membuktikan bahwa isi payload tidak berubah satu byte pun sejak server menyegelnya pada sealedAt. Tanda tangan **tidak** membuktikan bahwa kamera benar-benar menyaksikan peristiwa di dunia nyata — frame berasal dari klien. Spesifikasi ini jujur soal batasan tersebut di setiap bagian yang relevan.

1.1 Lingkungan & deployment

Properti	Nilai
Framework	Next.js 16 (App Router), React 19, TypeScript (strict)
Runtime semua route	nodejs (dideklarasikan <code>export const runtime = "nodejs"</code>)
Hosting	Vercel — https://dashai-mu.vercel.app
Base URL produksi	https://dashai-mu.vercel.app
Base URL lokal	http://localhost:3000
Library krypto	@noble/ed25519@^3.1.0, @noble/hashes@^2.2.0
Renderer PDF	@react-pdf/renderer@^4.5.1
Generator QR	qrcode@^1.5.4
Lisensi	Apache-2.0

Semua route berada di bawah direktori `app/api/` dan diekspor sebagai App Router Route Handlers (`app/api/seal/route.ts`, `app/api/verify/route.ts`, `app/api/public-key/route.ts`, `app/api/report/route.ts`).

1.2 Konvensi umum

Konvensi	Ketentuan
Format body request	JSON (Content-Type: <code>application/json</code>) untuk semua endpoint POST.
Format body response	JSON, kecuali POST <code>/api/report</code> yang mengembalikan <code>application/pdf</code> saat sukses.
Encoding	UTF-8.
Penamaan field	camelCase pada JSON; istilah hukum tetap Bahasa Indonesia (mis. pasal, ayat, sanksi).
Pesan error	Selalu Bahasa Indonesia, di field <code>error</code> (bertipe string), opsional <code>reason</code> .
Waktu (timestamp)	Epoch milidetik (number), berbasis <code>Date.now()</code> di server.
Hash	SHA-256, dikodekan hex lowercase.
Tanda tangan	Ed25519, dikodekan hex lowercase (lihat catatan format di bawah).
Idempotensi	<code>/api/seal</code> tidak idempoten — setiap pemanggilan menstempel <code>sealedAt</code> baru. <code>/api/verify</code> , <code>/api/public-key</code> , <code>/api/report</code> murni fungsi dari input.
Status diam (statefulness)	Tidak ada. Verifikasi bersifat <i>self-contained</i> ; tidak ada pencarian basis data.

1.2.1 Catatan format tanda tangan (penting)

Anotasi tipe pada `lib/evidence/types.ts` (`SealedEvidence.signature`) menyebut “base64url Ed25519 signature”. **Implementasi aktual** (`lib/crypto/sign.ts`) menandatangani tanda tangan sebagai **hex** melalui `bytesToHex(sig)`, dan verifier (`lib/crypto/verify.ts`) membacanya kembali dengan `hexToBytes(sealed.signature)`. Format kawat (wire format) yang sesungguhnya karena itu adalah **hex 128 karakter** (64 byte). Konsumen API harus memperlakukan signature sebagai hex. Komentar tipe bersifat indikatif dan tidak mengubah perilaku runtime.

`payloadHash` adalah hex 64 karakter (SHA-256 32 byte). `publicKeyHex` adalah hex 64 karakter (kunci publik Ed25519 32 byte).

1.2.2 Identitas kunci (`keyId` / `publicKeyId`)

Server membaca satu-satunya rahasia, `DASHAI_SIGNING_KEY` (seed Ed25519 32-byte hex). Jika `env` ada dan cocok dengan regex `^[0-9a-fA-F]{64}$`, kunci dianggap **produksi**; jika hilang/

invalid, dipakai **kunci DEV** tetap yang ditandai jelas. keyId dibentuk sebagai prefiks + 16 karakter pertama dari kunci publik hex:

Mode	Pola keyId			Arti
Produksi	prod-<16	hex pubkey>	pertama	Disegel dengan kunci produksi. Otoritatif.
Development	dev-<16	hex pubkey>	pertama	Disegel dengan kunci DEV. Tidak boleh diperlakukan sebagai bukti otoritatif.

Konsumen harus memeriksa prefiks keyId/publicKeyId; laporan ber-prefiks dev- adalah demonstrasi, bukan bukti.

2 POST /api/seal

Menyegel payload bukti. Klien mengirim event pelanggaran terkonfirmasi; server menstempel waktu otoritatif (sealedAt), melampirkan snapshot sitasi hukum dari knowledge base, mengkanonikalisasi, melakukan hash SHA-256, lalu menandatangani dengan Ed25519. Private key tidak pernah meninggalkan server.

- **Method:** POST
- **Path:** /api/seal
- **Runtime:** nodejs
- **Auth:** tidak ada
- **Content-Type request:** application/json
- **Content-Type response:** application/json

2.1 Request body

```
{
  "event":      ViolationEvent,    // wajib
  "mediaHashes": { "frame"?, "faceCrop"?, "plateCrop"? }, // opsional, hex
SHA-256
  "device":     { "userAgent"?, "platform"? }           // opsional
}
```

Server membaca subset field dari event (lihat buildPayload di lib/evidence/payload.ts). Field media (blob/data URL) **tidak** ikut ditandatangani; yang ditandatangani hanyalah mediaHashes (SHA-256 dari byte media), sehingga payload berkomitmen pada citra tanpa membengkok oleh base64.

2.1.1 Field yang diakui dari event

Field	Tipe	Wajib	Catatan
id	string	ya	Menjadi eventId pada payload.
violation	ViolationKey	ya	Harus salah satu dari 12 kunci katalog; harus ada di CITATIONS.
subject	"self" \ "other"	ya	Subjek pelanggaran relatif terhadap pemilik dashAI.
capturedAt	number	ya	Epoch ms saat frame diambil (waktu klien).
confidence	number	tidak	Di-clamp server ke [0,1]; nilai non-finite menjadi 0.
vehicleClass	string	tidak	Kelas COCO, mis. car, motorcycle.
plateText	string \ null	tidak	Hasil OCR pelat; default null.
egoSpeedKmh	number \ null	tidak	Kecepatan diri sendiri dari GPS — akurat .
otherSpeedKmh	number \ null	tidak	Kecepatan kendaraan lain — estimasi/perkiraan .
speedLimitKmh	number \ null	tidak	Batas kecepatan dari OSM maxspeed.
location	GeoPoint \ null	tidak	Titik GPS.
road	RoadContext \ null	tidak	Konteks jalan dari OpenStreetMap.

ViolationKey yang sah (12): lawan-arus, tanpa-helm, penumpang-tanpa-helm, terobos-lampu-merah, langgar-marka, boncengan-lebih, melebihi-kecepatan, tanpa-sabuk, main-hp, tanpa-plat, tanpa-lampu-malam, motor-lampu-siang.

2.2 Validasi

Validasi dijalankan berurutan; pelanggaran pertama menghentikan proses dengan status terkait.

Urutan	Pemeriksaan	Status saat gagal	Pesan error
1	Body adalah JSON valid	400	Body JSON tidak valid.
2	event.id, event.violation, event.subject, event.capturedAt ada	400	Event tidak lengkap (butuh id, violation, subject, capturedAt).
3	event.violation ada di CITATIONS	400	Jenis pelanggaran (violation) tidak dikenal.
4	event.subject ∈ {self, other}	400	Subjek (subject) harus 'self' atau 'other'.
5	event.capturedAt bertipe number	400	Waktu pengambilan (capturedAt) harus berupa angka.

Setelah validasi, confidence dinormalisasi: `Number(event.confidence)` di-*clamp* ke `[0,1]`; jika tidak finite, menjadi 0. Lalu `sealedAt = Date.now()` distempel server, `buildPayload(...)` menyusun `EvidencePayload` kanonik (termasuk `LegalSnapshot` dari `citationFor(violation)`), dan `sealPayload(...)` menghasilkan `envelope`.

2.3 Response (200)

Content-Type: `application/json` — sebuah `SealedEvidence`:

Field	Tipe	Keterangan
payload	EvidencePayload	Payload kanonik yang ditandatangani (lihat tabel di bawah).
algorithm	"Ed25519"	Algoritma tanda tangan.
publicKeyId	string	keyId (prod-... atau dev-...).
payloadHash	string	SHA-256 hex dari payload kanonik.
signature	string	Tanda tangan Ed25519, hex 128 karakter.
sealedAt	number	Sama dengan <code>payload.sealedAt</code> (epoch ms, otoritatif).

2.3.1 Struktur EvidencePayload (batas kriptografis)

EvidencePayload adalah **batas kriptografis** — field-field inilah, diserialisasi secara kanonik (kunci objek diurutkan rekursif, undefined dibuang; lihat `lib/crypto/canonical.ts`), yang ditandatangani.

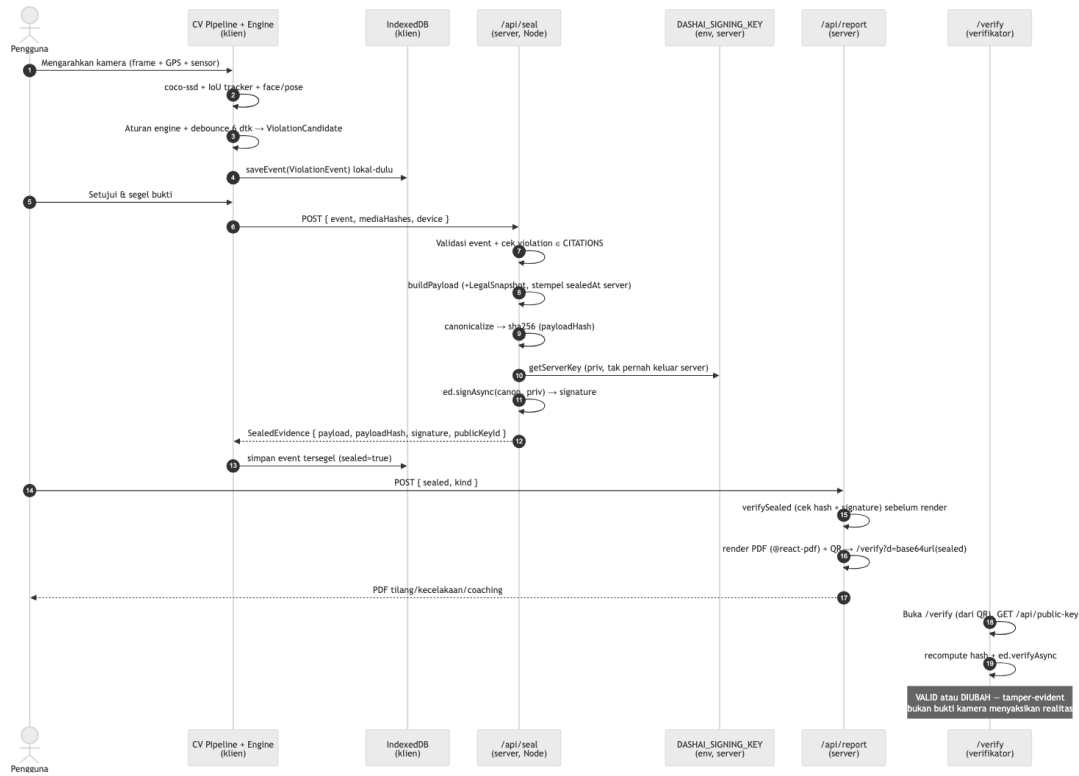
Field	Tipe	Keterangan
schema	"dashai.evidence.v1"	Versi skema payload (literal tetap).
eventId	string	Dari event.id.
violation	ViolationKey	Jenis pelanggaran.
subject	"self" \ "other"	Subjek.
capturedAt	number	Waktu klien (epoch ms).
sealedAt	number	Waktu server otoritatif (epoch ms).
confidence	number	[0,1] setelah clamp.
vehicleClass?	string	Kelas kendaraan.
plateText	string \ null	Teks pelat (atau null).
egoSpeedKmh	number \ null	GPS, akurat.
otherSpeedKmh	number \ null	Estimasi.
speedLimitKmh	number \ null	OSM maxspeed.
location	GeoPoint \ null	Titik GPS.
road	RoadContext \ null	Konteks jalan OSM.
mediaHashes	MediaHashes	SHA-256 hex dari byte media.
legal	LegalSnapshot	{ uu, pasal, ayat?, sanksi } dari KB sitasi.
device?	{ userAgent?, platform? }	Metadata perangkat opsional.

2.4 Errors

Status	Kondisi
400	Body bukan JSON, event tidak lengkap, violation tidak dikenal, subject invalid, atau capturedAt bukan angka.
200	Sukses — SealedEvidence.

Tidak ada autentikasi, sehingga tidak ada 401/403. Endpoint tidak melakukan deduplikasi sehingga tidak ada 409.

2.5 Diagram alur penyegelan



Gambar 1: Sequence: deteksi -> seal -> report -> verify

3 POST /api/verify

Endpoint kenyamanan untuk verifikasi sisi-server. Halaman publik /verify juga memverifikasi sepenuhnya di sisi klien menggunakan GET /api/public-key, sehingga **kepercayaan tidak pernah bergantung pada route ini**. Endpoint ada agar integrasi/skrip dapat memvalidasi envelope tanpa mengimplementasikan ulang krypto.

- **Method:** POST
- **Path:** /api/verify
- **Runtime:** nodejs
- **Auth:** tidak ada

3.1 Request body

```
{ "sealed": SealedEvidence }
```

sealed harus berupa envelope hasil /api/seal (atau dari QR/URL laporan). Server memuat kunci publiknya sendiri dan menjalankan `verifySealed(sealed, pubHex)`.

3.2 Validasi

Pemeriksaan	Status saat gagal	Pesan error
Body adalah JSON valid	400	Body JSON tidak valid.
sealed.signature dan sealed.payload ada	400	Envelope tidak lengkap.

3.3 Logika verifikasi

verifySealed (lib/crypto/verify.ts) menjalankan **dua pemeriksaan independen**, keduanya harus lulus:

1. **Hash cocok** — kanonikalisasi ulang sealed.payload, hitung SHA-256, bandingkan dengan sealed.payloadHash. Membuktikan payload tidak diedit.
2. **Tanda tangan valid** — ed.verifyAsync(signature, canon, publicKey) atas byte kanonik. Membuktikan envelope ditandatangani oleh pemegang private key.

3.4 Response (200)

Content-Type: application/json — sebuah VerificationResult:

Field	Tipe	Keterangan
valid	boolean	hashMatches && signatureValid.
reason	string	Penjelasan Bahasa Indonesia (lihat tabel).
hashMatches	boolean	Hasil pemeriksaan hash.
signatureValid	boolean	Hasil pemeriksaan tanda tangan.
publicKeyId	string	sealed.publicKeyId.
checkedAt	number	Date.now() saat verifikasi.

3.4.1 Pesan reason

Kondisi	reason
Valid	Tanda tangan sah dan isi laporan utuh (tidak diubah sejak disegel).
Hash tidak cocok	Hash payload tidak cocok – isi laporan telah diubah setelah disegel.
Tanda tangan invalid	Tanda tangan Ed25519 tidak valid untuk kunci publik ini.

Penting: HTTP 200 dikembalikan bahkan saat envelope **tidak valid**. Hasil verifikasi dibawa di body (valid: false), bukan pada status HTTP. Status 4xx hanya untuk request yang cacat bentuk, bukan untuk envelope yang gagal verifikasi.

3.5 Errors

Status	Kondisi
400	Body bukan JSON atau envelope tidak lengkap.
200	Verifikasi dijalankan — periksa valid di body untuk hasilnya.

4 GET /api/public-key

Mempublikasikan kunci publik Ed25519 dashAI agar siapa pun dapat memverifikasi laporan tersegel tanpa mempercayai antarmuka dashAI. Inilah dasar dari janji *tamper-evident*: verifikasi tidak memerlukan akses ke private key maupun ke server dashAI selain pengambilan kunci publik ini (yang bisa di-mirror/pin).

- **Method:** GET
- **Path:** /api/public-key
- **Runtime:** nodejs
- **Auth:** tidak ada
- **Cache:** Cache-Control: public, max-age=3600

4.1 Response (200)

Content-Type: application/json:

Field	Type	Keterangan
publicKeyHex	string	Kunci publik Ed25519, hex 64 karakter (32 byte).
keyId	string	prod-... atau dev-... (16 hex pertama pubkey).
algorithm	"Ed25519"	Algoritma.
isDev	boolean	true bila server berjalan dengan kunci DEV.

4.2 Errors

Endpoint hanya membaca/derive kunci dari env dan tidak menerima input; pada kondisi normal selalu 200. Tidak ada jalur error tervalidasi dalam handler.

5 POST /api/report

Merender bukti tersegel menjadi laporan PDF tertanda tangan dengan QR ke halaman verifikasi mandiri. Data verifikasi berjalan **di dalam** dokumen (QR + URL mengkodekan envelope

SealedEvidence lengkap sebagai base64url), sehingga verifikasi *self-contained* tanpa pencarian basis data.

- **Method:** POST
- **Path:** /api/report
- **Runtime:** nodejs
- **Auth:** tidak ada
- **Content-Type request:** application/json
- **Content-Type response:** application/pdf (sukses) atau application/json (error)

5.1 Request body

```
{
  "sealed": SealedEvidence,    // wajib
  "kind":   ReportKind         // opsional
}
```

ReportKind ∈ {tilang, kecelakaan, coaching}. Bila kind tidak diberikan, server memilih default berdasarkan subjek:

sealed.payload.subject	Default kind
self	coaching
other	tilang

5.1.1 Jenis laporan (kinds)

kind	Tujuan	Sisi
tilang	Laporan dugaan pelanggaran terhadap pengendara lain (gaya laporan tilang).	Penegakan terhadap orang lain.
kecelakaan	Dokumentasi bukti terkait kecelakaan.	Dapat menindak maupun melindungi.
coaching	Self-coaching: umpan balik atas pelanggaran diri sendiri agar tidak terulang.	Perlindungan/perbaikan diri.

5.2 Alur pemrosesan

1. Parse body; jika gagal → 400.
2. Cek sealed.payload dan sealed.signature ada; jika tidak → 400.
3. Cek sealed.payload.violation ada di CITATIONS; jika tidak → 400.
4. Muat kunci server (pubHex, isDev), jalankan verifySealed. **Bila tidak valid** → 422 (laporan resmi tidak dibuat).
5. Tentukan reportKind (dari kind atau default subjek).

6. Encode `envelope: verifyUrl = ${origin}/verify?d=${base64url(JSON.stringify(sealed))}`.
7. Buat QR dari `verifyUrl` (best-effort: jika gagal, URL tetap dicetak di PDF).
8. Render PDF via `@react-pdf/renderer (ReportDocument)`; jika render gagal $\rightarrow$ 500.
9. Kembalikan byte PDF.

5.3 Response (200)

- **Content-Type:** `application/pdf`
- **Content-Disposition:** `attachment; filename="dashAI-<kind>-<eventId>.pdf"`
- **Body:** byte PDF.

PDF memuat: ringkasan pelanggaran, snapshot sitasi UU 22/2009, status verifikasi, QR ke `/verify?d=...`, serta penanda `isDev` bila relevan.

5.4 Errors

Status	Kondisi	Body
400	Body bukan JSON.	{ "error": "Body JSON tidak valid." }
400	Envelope tidak lengkap (payload/signature hilang).	{ "error": "Envelope tidak lengkap." }
400	violation tidak dikenal.	{ "error": "Jenis pelanggaran (violation) tidak dikenal." }
422	Envelope gagal verifikasi (hash/tanda tangan).	{ "error": "Envelope tidak dapat diverifikasi — laporan resmi tidak dibuat.", "reason": <reason> }
500	Render PDF gagal.	{ "error": "Gagal membuat dokumen PDF laporan." }
200	Sukses — byte PDF.	<code>application/pdf</code>

`/api/report` adalah **satu-satunya** endpoint yang menolak envelope tidak valid (422) — ia menolak menerbitkan laporan yang tidak dapat diverifikasi. Hal ini berbeda dengan `/api/verify` yang selalu 200 dan melaporkan hasil di body.

6 Model error & kode status

dashAI memakai kode status HTTP secara konservatif dan konsisten di seluruh endpoint.

Status	Makna di dashAI	Endpoint
200 OK	Sukses. Untuk <code>/api/verify</code> , perhatikan: keberhasilan request $\neq$ envelope valid.	semua
400 Bad Request	Body bukan JSON, field wajib hilang, atau nilai enum/tipe tidak sah.	seal, verify, report
422 Unprocessable Entity	Bentuk request benar tetapi isi tidak dapat diproses — khusus: envelope gagal verifikasi pada <code>/api/report</code> .	report
500 Internal Server Error	Kegagalan tak terduga saat render PDF.	report

6.1 Bentuk objek error (JSON)

```
{
  "error": string,    // selalu ada, Bahasa Indonesia
  "reason?": string   // hanya pada 422 /api/report (penjelasan verifikasi)
}
```

6.2 Prinsip desain error

- **Pesan dalam Bahasa Indonesia** dan ditujukan langsung ke developer/operator, bukan kode mesin.
- **Tidak ada bocoran internal** — pesan deskriptif tanpa stack trace atau detail sistem.
- **200 untuk verifikasi gagal** pada `/api/verify`: kegagalan verifikasi adalah hasil yang sah, bukan error transport.
- **422 untuk penolakan penerbitan** pada `/api/report`: server menolak menjadi penerbit laporan yang tidak terverifikasi.
- **Tidak ada autentikasi** → tidak ada 401/403. Tidak ada state/duplikasi → tidak ada 409. Tidak ada rate limit aplikasi → tidak ada 429 di lapisan aplikasi (mitigasi platform pada Vercel terpisah).

7 Pertimbangan keamanan

7.1 Permukaan rahasia minimal

Satu-satunya rahasia adalah `DASHAI_SIGNING_KEY` — seed Ed25519 32-byte (hex 64 karakter). Ia dibaca di `lib/crypto/keys.ts`, di-cache di memori proses, dan **tidak pernah meninggalkan server**. Tidak ada kunci API pihak ketiga; OpenStreetMap Overpass dan CDN model diakses tanpa kredensial.

7.2 Kunci DEV vs produksi

Tanpa DASHAI_SIGNING_KEY yang valid, server memakai **kunci DEV publik yang di-hardcode** agar aplikasi jalan langsung. Bukti yang disegel DEV ber-keyId dev-... dan **bukan otoritatif**. Konsekuensi keamanan: jika produksi salah konfigurasi (env hilang), semua laporan otomatis ber-prefiks dev-, sehingga kesalahan ini **terlihat** oleh verifier mana pun, bukan tersembunyi. Verifier harus menolak/menandai envelope dev- dalam konteks otoritatif.

7.3 Batas kepercayaan (trust boundary)

Lapis	Dipercaya?	Alasan
Frame kamera (klien)	Tidak	Bisa diarahkan ke layar; tidak ada attestation.
capturedAt (klien)	Tidak (informasional)	Waktu klien; dapat dimanipulasi.
sealedAt (server)	Ya	Distempel server via <code>Date.now()</code> .
Private key (server)	Ya (rahasia)	Tidak pernah keluar server.
Public key (/api/public-key)	Ya (publik)	Dipublikasikan untuk verifikasi independen.

7.4 Apa yang dibuktikan dan tidak dibuktikan tanda tangan

- **Dibuktikan:** isi EvidencePayload tidak berubah satu byte pun sejak sealedAt. Mengubah pelat/kecepatan/pasal → hash tidak cocok → terdeteksi.
- **TIDAK dibuktikan:** bahwa kamera menyaksikan peristiwa nyata. Karena itu **tamper-evident**, bukan **tamper-proof**. Penilaian akhir tetap pada pihak berwenang.
- **Jalan ke produksi:** device attestation (Play Integrity / App Attest), kontinuitas GPS, stempel waktu server, dan dashcam perangkat keras khusus untuk menaikkan biaya pemalsuan.

7.5 Privasi (selaras UU 27/2022 PDP)

- **Deteksi wajah, bukan pengenalan identitas;** wajah & pelat **di-blur** secara default di antarmuka.
- **Local-first:** bukti disimpan di IndexedDB; server **hanya** menerima payload yang **secara eksplisit** disegel pengguna.
- **Komitmen via hash:** byte media tidak ditandatangani langsung; hanya mediaHashes (SHA-256) masuk ke payload, mengurangi paparan data pribadi dalam envelope yang beredar.

7.6 Integritas verifikasi mandiri

Karena envelope lengkap dikodekan ke dalam URL/QR laporan dan kunci publik dipublikasikan, verifikasi tidak bergantung pada basis data atau pada kejujuran UI dashAI. Verifier dapat memuat ulang kunci publik secara independen dan menjalankan `verifySealed` (kode yang sama berjalan di browser dan server).

7.7 Validasi input & ketahanan

- Semua endpoint membungkus `req.json()` dalam `try/catch` → 400 pada JSON cacat.
- `confidence` di-*clamp* ke `[0,1]`; nilai non-finite → 0.
- `violation` divalidasi terhadap CITATIONS di `/api/seal` dan `/api/report`.
- `/api/report` memverifikasi ulang sebelum render — tidak ada PDF “resmi” untuk envelope invalid.

7.8 Catatan demo (jujur soal batasan)

Demo saat ini berjalan via **kamera ponsel** dan menghasilkan dokumen yang **bukan** dokumen resmi kepolisian. Sitasi bersifat indikatif; kecepatan kendaraan lain bersifat **estimasi**. Tidak ada autentikasi pengguna, rate limiting tingkat aplikasi, atau attestation perangkat pada tahap ini.

8 Contoh request/response

Bentuk di bawah menggunakan tipe nyata dari `lib/evidence/types.ts`. Nilai hex tanda tangan/hash dipersingkat dengan elipsis untuk keterbacaan; pada respons nyata mereka utuh.

8.1 Menyegel pelanggaran “melawan arah” (kendaraan lain)

Request

```
curl -X POST https://dashai-mu.vercel.app/api/seal \
-H "Content-Type: application/json" \
-d '{
  "event": {
    "id": "evt_8clf2a",
    "violation": "lawan-arus",
    "subject": "other",
    "confidence": 0.88,
    "capturedAt": 1750464000000,
    "vehicleClass": "motorcycle",
    "plateText": null,
    "egoSpeedKmh": null,
    "otherSpeedKmh": null,
    "speedLimitKmh": null,
    "location": { "lat": -6.2146, "lng": 106.8451, "accuracy": 8, "speedMps":
null, "headingDeg": 210, "timestamp": 1750464000000 },
    "road": { "name": "Jl. M.H. Thamrin", "oneway": true, "bearingDeg": 30,
"maxspeedKmh": 50 }
  },
  "mediaHashes": { "frame":
"9f86d081884c7d659a2feaa0c55ad015a3bf4f1b2b0b822cd15d6c15b0f00a08" },
  "device": { "userAgent": "Mozilla/5.0 (Linux; Android 14)", "platform":
"Android" }
}'
```

Response 200 — SealedEvidence

```

{
  "payload": {
    "schema": "dashai.evidence.v1",
    "eventId": "evt_8clf2a",
    "violation": "lawan-arus",
    "subject": "other",
    "capturedAt": 1750464000000,
    "sealedAt": 1750464003120,
    "confidence": 0.88,
    "vehicleClass": "motorcycle",
    "plateText": null,
    "egoSpeedKmh": null,
    "otherSpeedKmh": null,
    "speedLimitKmh": null,
    "location": { "lat": -6.2146, "lng": 106.8451, "accuracy": 8, "speedMps":
null, "headingDeg": 210, "timestamp": 1750464000000 },
    "road": { "name": "Jl. M.H. Thamrin", "oneway": true, "bearingDeg": 30,
"maxspeedKmh": 50 },
    "mediaHashes": { "frame":
"9f86d081884c7d659a2feaa0c55ad015a3bf4f1b2b0b822cd15d6c15b0f00a08" },
    "legal": {
      "uu": "Undang-Undang Republik Indonesia Nomor 22 Tahun 2009 tentang Lalu
Lintas dan Angkutan Jalan (UU LLAJ)",
      "pasal": "Pasal 287",
      "ayat": "ayat (1)",
      "sanksi": "Pidana kurungan paling lama 2 (dua) bulan atau denda paling
banyak Rp500.000,00 (lima ratus ribu rupiah). Sifatnya alternatif (kurungan ATAU
denda).",
    },
    "device": { "userAgent": "Mozilla/5.0 (Linux; Android 14)", "platform":
"Android" },
    },
    "algorithm": "Ed25519",
    "publicKeyId": "prod-3b6a1f0c9d2e4a55",
    "payloadHash":
"2c26b46b68ffc68ff99b453c1d30413413422d706483bfa0f98a5e886266e7ae",
    "signature": "a3f1c0...(hex 128 karakter)...9e2b",
    "sealedAt": 1750464003120
  }
}

```

Catatan: nilai legal di atas dikutip **persis** dari lib/legal/citations.ts untuk kunci lawan-arus (Pasal 287 ayat (1), UU 22/2009). Snapshot ini diresolusi server saat seal, bukan dari klien.

8.2 Menyegel “melebihi kecepatan” (diri sendiri, akurat via GPS)

Request (ringkas)

```
{
  "event": {
    "id": "evt_speed_01",
    "violation": "melebihi-kecepatan",
    "subject": "self",
    "confidence": 0.95,
    "capturedAt": 1750470000000,
    "egoSpeedKmh": 78,
    "speedLimitKmh": 50,
    "location": { "lat": -6.30, "lng": 106.83, "speedMps": 21.7, "headingDeg":
95, "timestamp": 1750470000000 },
    "road": { "name": "Jl. T.B. Simatupang", "oneway": false, "maxspeedKmh": 50 }
  }
}
```

Snapshot legal yang akan disematkan (dari melebihi-kecepatan): Pasal 287 ayat (5), UU 22/2009 — “Pidana kurungan paling lama 2 (dua) bulan atau denda paling banyak Rp500.000,00 (lima ratus ribu rupiah).”

8.3 Verifikasi envelope

Request

```
curl -X POST https://dashai-mu.vercel.app/api/verify \
  -H "Content-Type: application/json" \
  -d '{ "sealed": { /* SealedEvidence dari /api/seal */ } }'
```

Response 200 — valid (VerificationResult)

```
{
  "valid": true,
  "reason": "Tanda tangan sah dan isi laporan utuh (tidak diubah sejak
disegel).",
  "hashMatches": true,
  "signatureValid": true,
  "publicKeyId": "prod-3b6a1f0c9d2e4a55",
  "checkedAt": 1750464100000
}
```

Response 200 — telah diubah

```
{
  "valid": false,
  "reason": "Hash payload tidak cocok – isi laporan telah diubah setelah
disegel.",
  "hashMatches": false,
  "signatureValid": false,
  "publicKeyId": "prod-3b6a1f0c9d2e4a55",
  "checkedAt": 1750464100000
}
```

8.4 Mengambil kunci publik

Request

```
curl https://dashai-mu.vercel.app/api/public-key
```

Response 200

```
{
  "publicKeyHex": "3b6a1f0c9d2e4a55...(hex 64 karakter)...",
  "keyId": "prod-3b6a1f0c9d2e4a55",
  "algorithm": "Ed25519",
  "isDev": false
}
```

8.5 Membuat laporan PDF

Request

```
curl -X POST https://dashai-mu.vercel.app/api/report \
  -H "Content-Type: application/json" \
  -o dashAI-tilang-evt_8clf2a.pdf \
  -d '{ "sealed": { /* SealedEvidence */ }, "kind": "tilang" }'
```

Response 200 — biner PDF dengan header:

```
Content-Type: application/pdf
Content-Disposition: attachment; filename="dashAI-tilang-evt_8clf2a.pdf"
```

Response 422 — envelope gagal verifikasi:

```
{
  "error": "Envelope tidak dapat diverifikasi – laporan resmi tidak dibuat.",
  "reason": "Tanda tangan Ed25519 tidak valid untuk kunci publik ini."
}
```

9 Tabel ringkasan gaya OpenADR

Ringkasan padat seluruh permukaan API dashAI.

Operasi	Method & Path	Auth	Body request	Sukses	Content-Type sukses	Error	Idempoten
Seal evidence	POST /api/seal	—	{ event, mediaId, device? }	200 SealedEvidence	application/json	400	Tidak
Verify envelope	POST /api/verify	—	{ sealed, verificationResult }	200 VerificationResult	application/json	400	Ya
Get public key	GET /api/public-key	—	—	200 { publicKeyId, algorithm, isDev }	application/json	—	Ya
Render report	POST /api/report	—	{ sealed, kind? }	200 byteapplication/pdf	application/pdf	400, 422, 500	Ya

9.1 Matriks tipe inti

Tipe	Definisi (lib/evidence/types.ts)
Subject	"other" \ "self"
ViolationKey	12 kunci: lawan-arus, tanpa-helm, penumpang-tanpa-helm, terobos-lampu-merah, langgar-marka, boncengan-lebih, melebihi-kecepatan, tanpa-sabuk, main-hp, tanpa-plat, tanpa-lampu-malam, motor-lampu-siang
ReportKind	"tilang" \ "kecelakaan" \ "coaching"
EvidencePayload.schema	"dashai.evidence.v1" (literal)
SealedEvidence.algorithm	"Ed25519" (literal)
GeoPoint	{ lat, lng, accuracy?, speedMps?, headingDeg?, timestamp }
RoadContext	{ name?, oneway?, bearingDeg?, maxspeedKmh? }
MediaHashes	{ frame?, faceCrop?, plateCrop? } (hex SHA-256)
LegalSnapshot	{ uu, pasal, ayat?, sanksi }
VerificationResult	{ valid, reason, hashMatches, signatureValid, publicKeyId, checkedAt }

9.2 Pemetaan pelanggaran → sitasi UU 22/2009

Konsisten persis dengan lib/legal/citations.ts (12/12 terverifikasi, 3-voter adversarial).

ViolationKey	Pasal	Ayat	Denda maks	Kurungan maks
lawan-arus	Pasal 287	ayat (1)	Rp500.000	2 bulan
tanpa-helm	Pasal 291	ayat (1)	Rp250.000	1 bulan
penumpang-tanpa-helm	Pasal 291	ayat (2)	Rp250.000	1 bulan
terobos-lampu-merah	Pasal 287	ayat (2)	Rp500.000	2 bulan
langgar-marka	Pasal 287	ayat (1)	Rp500.000	2 bulan
boncengan-lebih	Pasal 292	ayat (9)	Rp250.000	1 bulan
melebihi-kecepatan	Pasal 287	ayat (5)	Rp500.000	2 bulan
tanpa-sabuk	Pasal 289	ayat (6)	Rp250.000	1 bulan
main-hp	Pasal 283	ayat (1)	Rp750.000	3 bulan
tanpa-plat	Pasal 280	ayat (1)	Rp500.000	2 bulan
tanpa-lampu-malam	Pasal 293	ayat (1)	Rp250.000	1 bulan
motor-lampu-siang	Pasal 293	ayat (2)	Rp100.000	15 hari

Seluruh sitasi merujuk **UU No. 22 Tahun 2009 tentang Lalu Lintas dan Angkutan Jalan (LLAJ)**. Snapshot legal yang ditandatangani diambil dari knowledge base ini saat seal, sehingga laporan berkomitmen pada teks pasal yang berlaku.